

Benchmark - Risk Management Assessment and Control (PPHC)

Grand Canyon University

ITT-430 IT Security Driven Systems Administration

Professor Timothy Montgomery

Liela Pressley

January 19, 2025

PPHC Framework for Managing Risk

Pike's Peak Health Care seeks to proactively mitigate risks that pose a threat to the well being of internal and external environments for the betterment of our staff and patients. The external factors that each element of our risk management plan considers are the patients, suppliers, laws/regulations, healthcare industry standards, known threats, vulnerabilities and attack vendors, and government agencies such as NIST and DHS. The internal factors that are considered include the governance structure that is established within PPHC, stakeholders, upholding the PPHC culture, the current information security program and bettering the experience of our policy/planning and risk management for all employees.

PPHC is dedicated to upholding all necessary standards and regulations that are required for the proactive protection of sensitive information of its patients and employees. These corporate requirements include:

- a. **HIPAA (Health Insurance Portability and Accountability Act)**; a regulation that focuses on the privacy and security of protected health information. In upholding this law PPHC must comply with the Privacy Rule which is to ensure that sensitive data is confidential, the Security Rule which focuses on the electronic health information, and the Breach Notification Rule which requires you act quickly to notify the Dept of Health and Human Services within 60 days of discovering the breach.
- b. **HITECH (Health Information Technology for Economic and Clinical Health Act)**; a regulation that enforces the adoption of electronic health records and

supports technology across the US, strengthens HIPAA privacy and security rules, and more.

- c. **HITRUST (Health Information Trust Alliance)**; a standards development organization that provides tools, assessment platforms and assurance programs to help manage data, information risk and compliance effectively by crossing HIPAA, SOC 2, NIST, and ISO 27001.
- d. **QSR, or the Quality System Regulation, or FDA 21 CFR Part 820**; is a framework that ensures that medical devices meet strict qualifications and safety standards.
- e. **NIST CSF** is considered a voluntary framework but PPHC will uphold its guidelines to manage and reduce cybersecurity risks as the organization tailors it to its exact needs alongside HIPAA Security Rules compliance. It includes the core functions: Identify, Protect, Detect, Respond and Recover.
- f. **PCI DSS (Payment Card Industry Data Security Standard)** enforces the necessity of data security of credit and debit card transactions.

Maintaining compliance with each of these standards must be made a top priority with all information/data/assets that are identified to be sensitive and high priority. Failure to comply with these data privacy/security requirements can result in PPHC patients to suffer as medical records can be exposed to medical identity theft, fraud, scams, hinder access to healthcare, obtain finances, or even hinder employment prospects. If information is withheld or modified by unauthorized parties, the chance of misdiagnosis or treatment can increase or delay the time for operations which can worsen patient care. PPHC values the care of all it serves locally and the

community as well as our staff, if data is obtained/modified/captured by malicious actors, PPHC can experience a lack of trust from its patients with treatment plans and medications.

Failure to comply with these regulations can all result in PPHC having to pay over \$4 million of fines, face patient lawsuits, pay for cybersecurity insurance, legal/remediation fees, and even face jail time in criminal charges.

Analyze threat information to identify vulnerabilities and potential for exploitation.

1. PPHC has outdated systems that require updating; as part of our security plan within the next 2 years, we seek to remediate this vulnerability. In the meantime, having an outdated system can increase risk for new security threats to emerge and not be addressed via updates/patches being released.
2. Medical devices are being updated to IoMT (Internet of Medical Things) which leaves medical devices vulnerable on the network with minimal security features. Attackers can exploit the vulnerabilities within the medical devices to access PPHC's network then gain access to ePHI.
3. Phishing and other social engineering attacks are a common vulnerability that all healthcare organizations must face. From emails to messages that sound professional or relevant or from a familiar face can convince an internal employee to click on a malicious link, download malware and compromise the network, gaining access to patient data and unauthorized access to healthcare systems.
4. Ransomware is another threat that is commonly used to attack healthcare systems to gain access to patient data, lockdown hospital systems, and even restrict the operation of equipment.

5. DDoS (Distributed Denial of Service) attacks are a common threat to healthcare organizations as attackers will flood the hospital's website with fake requests causing it to crash, go offline and allow for malicious attackers to take control of devices, within the network and bombard the servers which disrupts critical online servers, accessibility to resources and ability to schedule appointments.

Analyze and evaluate systems with respect to maintaining operations in the presence of risks and threats.

Providing safe, efficient and quality patient care is the top priority of PPHC, to provide high level care, it is essential to map out the 8 ways we implement care and to be proactive in ensuring information security compliance throughout each of them. Each category is listed by data classification levels from public to restricted.

Private- Virtual care provided via PPHC website. Providing virtual care provides patient care from the convenience of their home and encrypted connection but if need be this service can be temporarily down to save resources in the midst of a recovery plan implementation.

Internal- Rapid Communication of Lab/Imaging Services to Patients and Doctors requires encrypted, quick data transmission to patients and other doctors

Internal In Home Care Electronic Documentation- WLAN secure connection with VPN so that in home care staff can input updates on their patient and treatment plan in real time, securely

Internal- Walk In Check In of Patients- requires secure software to input, secure, retrieve or save the patient data so that can be made available for the patient's future care. Will also require security of SSNs, payment information, birthdates, etc.

Internal 24 hour Emergency/Trauma Care- requires 24hr availability regardless of the risk, threat or anomaly.

Internal- Patients having to pay co-pays for surgeries, doctors visits, or store health insurance plans within PPHC systems require data security of debit/credit card information being used in transactions or stored within the system

Confidential- Web Domain that connects all locations with patient information- allows medical staff to provide treatment with updated medical records from all locations (specialty to primary, etc).

Confidential-Healthcare workers logging on and off their accounts-require compliant credentials as their accounts provide restricted access to different levels of sensitive information on patients, specific equipment, and to their personal sensitive information.

Where is the Risk to PPHC Information Assets

IS Component	Risk Management Components	Asset Value	Asset Risk Response Recommendation
People	External- Patients, Service Providers, Medical Device Vendors Internal- Doctors, Nurses, Medical Assistants, Specialists, Medical Staff Members, IT Staff Members,Utilities Staff Members	High	Ensure that all internal personnel are regularly trained and informed on the current risks and threats and how to identify social engineering attacks.
Technology	IT Medical Data Transmission Procedures, Log	Critical	Enforce regular credential

	On/Off, Medical Software, Operating Systems, Medical Devices, IoT Devices, IoM Devices,		updates, ensure that all devices are updated and patched, ensure that all transmission is encrypted and least privilege accessibility is enforced.
Enterprise	PPHC Business sensitive procedures, Data Storage, WLAN Components, Cloud-based storage/services,	Critical	Ensuring that all devices are updated and patched, review service providers terms of security of cloud services, ensure that business sensitive procedures are compliant.

Being able to identify and assess risk is essential to system security as it proactively allows for leadership and employees to prevent and prepare for when or if a threat becomes an exploited attack. First PPHC will adopt the NIST model of risk analysis; startin with identifying the threat source, the likelihood of initiation, the potential threat events and the likelihood of a successful exploit. By determining these three factors the severity of the vulnerability can be calculated within the current conditions plus the implemented security controls in place. NIST defines adverse impact to be the result of the vulnerability which then produces organizational risk. If a vulnerability that is discovered is considered to be fully managed by an existing security control it can be set aside. If it is only partially controlled then the IS team along with department management must estimate the percentage of vulnerability that is controlled. One method is to find what controls are recommended as part of the security program, describe the level of

implementation then research the vulnerabilities independent of NIST to gain complete understanding. This ensures that the controls that are selected are fully applicable to the organization and not cherry picked blindly. Another method is to assess the risk likelihood by scoring the event with a rating scale based on the need of that hindered process by the organization.

There are 4 main risk management methodologies that PPHC considered such as: the OCTAVE Method, FAIR, ISO Standards for InfoSec Risk Management, and NIST Risk Management Framework. PPHC decided in favor of using the NIST ISO 31000 Risk Management Principles, Framework and Process as it presents a way to identify, respond, monitor and assess risks from different angles.

OCTAVE represents Operationally Critical Threat, Asset, and Vulnerability Evaluation which allows PPHC to balance protection of information assets against the costs of providing protection and detection controls. It provides a great alternative approach to understanding workflows but unfortunately it works for organizations with 300 or less users which is not appropriate for PPHC. The next method is FAIR which is the Factor Analysis of Information Risk framework which is cost effective, has great credibility and is a strong foundation for information risk management. FAIR has 10 steps broken down into 4 stages including: Identifying Scenario Components, Evaluating Loss Event Frequency, Evaluating Probable Loss Magnitude and Derive and Articulate Risk. By using Loss Event Frequency and Probable Loss Magnitude, PPHC is able to identify and attack different levels of risk and loss factors efficiently and in order or priority without getting lost in the overwhelming list of processes and probabilities. ISO Standards for InfoSec Risk Management contain several standards but provide a general outlook on information security and cybersecurity so they can be used as general

guidelines rather than a step by step format. The NIST Risk management framework provides an industry standard approach to risk management that provides an approach that addresses leadership, value creation/protection and the step by step procedures for risk identification, analysis, evaluation and reporting.

How Severe is the Risk to PPHC Information Assets

How Severe would the outcome be if risk occurred?					
What is the probability that the risk will happen?	Insignificant 1	Minor 2	Significant 3	Major 4	Severe 5
5 Almost Certain	Medium 5	High 10	Very High 15	Extreme 20	Extreme 25
4 Likely	Medium 4	Medium 8	High 12	Very High 16	Extreme 20
3 Moderate	Low 3	Medium 6	Medium 9	High 12	Very High 15
2 Unlikely	Very Low 2	Low 4	Medium 6	Medium 8	High 10
1 Rare	Very Low 1	Very Low 2	Low 3	Medium 4	Medium 5

Some general risk mitigation strategies for economic and healthcare practices include avoidance such as avoiding certain service providers or processes that can increase the risk of data breaches and boost patient experience. Risk reduction which means reducing the potential for the risk to occur through implementing employee awareness/training programs so they can actively avoid or proactively take action against social engineering attacks (phishing). Risk transference, which is mitigating the risk by shifting the negative effects to a third party such as investing in cybersecurity insurance. Lastly, is risk acceptance, PPHC has low tolerance for this method but it is unavoidable in some cases where the exposure to risk is inevitable but we are ready with data backups to ensure that operability, confidentiality, and availability is upheld as much as possible.

How Much Risk is Acceptable to PPHC

PPHC is dedicated to improving the health and quality of life for the members of our community and to be the preferred provider of healthcare. Like any healthcare organization, we understand that there are unavoidable risks that are to be addressed that include patient data, regulatory compliance, finances, and technology related risks. PPHC has very low tolerance for risks that compromise patient welfare, safety, treatment outcomes, quality of care and is committed to mitigating risks that can compromise medical treatment, patient records, employee personal information and medical procedures of any kind. PPHC has a zero-tolerance policy for risks that are caused or can cause a non-compliance with healthcare regulations and HIPAA, HITECH, HITRUST, QSR, NIST and PCI DSS. Compliance with these regulations ensures that PPHC remains reputable, trustworthy and clear of legal consequences. Data security is very important to us and we accept low to moderate risks related to emerging technologies

specifically to newly implemented medical devices and systems to protect patient and employee data.

Part 5: Control Risk

PPHC seeks to provide the best healthcare to our patients in our community and in our operations to remain proactive in our compliance to standards, regulations and frameworks that are required of our organization. PPHC has a low to zero tolerance of any risk that can cause harm to our patients' records, treatment plan/procedures, and operational processes that can affect our provision of healthcare. In efforts to identify, assess, monitor and mitigate risks within the company, PPHC is dedicated to implementing the NIST ISO 31000 Risk Management Principles, Framework and Process as it provides guidelines for leadership communication, effective risk identification and management and asset identification and protection. PPHC will work to continuously improve a culture that is open and honest so that there is a clear communication pattern for sharing risks and how to implement necessary response plans. Within this culture, PPHC is delegating a Risk Management task force which contains senior leadership and each department head to provide their understanding of the daily activities which will allow for insightful risk identification, control implementation and effectiveness discussions and more. PPHC will dedicate a healthy financial budget to ensure that regulatory compliance controls are adhered to by conducting regular internal audits and outsource for external audits as well. In addition, there will be regular training for all staff members of PPHC to ensure they are aware of the information security risks relevant to their job responsibilities and how their role plays a part in mitigating it everyday. In addition, the cybersecurity team will ensure that a proper incident

response plan will be updated in relation to the assets identified and assessed risks to ensure that data is available, confidential and and still trustworthy if/when an incident occurs.